

SCPs & AWS Organizations

BaseStack Academy · AWS Cloud Accelerator

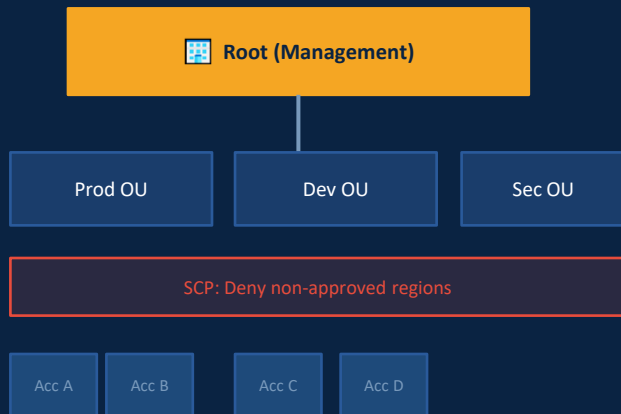
IAM & Security

Cohort 1

Beginner-Friendly

SAA-C03 Aligned

basestack.academy



1 Overview — Why Multi-Account Architecture Matters

FOUNDATION

2 Key Concepts — Definitions & Vocabulary

CORE KNOWLEDGE

3 Deep Dive — SCP Strategies & Inheritance

DEEPER LEARNING

4 How It Works — Step by Step

MECHANICS

5 Technical Deep Dive — SCP JSON & Permission Math

ADVANCED DETAIL

6 Architecture & Visual Model

VISUAL

7 Real-World Nigerian Scenario

CONTEXT

8 Common Mistakes & Exam Traps

EXAM PREP



Overview — Why This Matters

As organisations grow on AWS, managing security and governance across dozens of accounts using individual IAM policies becomes impossible. AWS Organizations solves this by letting you consolidate multiple AWS accounts under a single management umbrella — with a centralised control plane, unified billing, and hierarchical policy enforcement.

Service Control Policies (SCPs) are the enforcement mechanism. They act as a permissions ceiling on every account in your organisation — even an IAM Administrator in a member account cannot exceed what an SCP allows. Without SCPs, a single rogue developer could disable audit logging, spin up resources in prohibited regions, or incur uncapped costs. SCPs prevent this at scale.

WHY NOW?

Nigerian fintechs, banks, and enterprises are rapidly moving to multi-account AWS architectures — separate accounts for production, dev, and compliance.

SCPs are how their security teams enforce data residency requirements (e.g., no resources outside af-south-1 or eu-west-1), prevent cost overruns, and satisfy CBN and ISO 27001 audit requirements.

This topic appears directly in SAA-C03 Section 2: Design Secure Architectures.

Beginner Note

Think of AWS Organizations like a Nigerian holding company (e.g., Heirs Holdings). Each subsidiary is a separate AWS account. SCPs are the group-wide compliance rules the holding company imposes on every subsidiary — no subsidiary can override them.



Key Concepts — Know These Definitions

 *Study tip: Say each definition aloud — spoken repetition builds memory 3× faster than reading alone.*

AWS Organizations

A free global AWS service that groups multiple AWS accounts under one management account, enabling consolidated billing, centralised governance, and hierarchical policy enforcement across the entire account structure.

Management Account

The AWS account that creates the organisation. It holds full control — it can invite accounts, create OUs, and attach SCPs. Critically: the Management Account is NEVER restricted by SCPs, even if an SCP is attached to the root.

Organisational Unit (OU)

A logical folder inside the organisation hierarchy. You place AWS accounts inside OUs to group them by function (e.g., Production OU, Dev OU, Security OU). SCPs attached to an OU are automatically inherited by all accounts and nested OUs beneath it.

Service Control Policy (SCP)

A JSON policy document that defines the MAXIMUM permissions available in an account or OU. SCPs never grant access — they only restrict it. Effective permission = IAM Policy AND SCP. If SCP blocks it, no IAM policy can override that block.

FullAWSAccess SCP

The default SCP that AWS automatically attaches to every root, OU, and account when you enable SCPs. It allows all actions on all services. This is why SCPs start permissive — you add restrictions on top, rather than whitelisting from scratch.



Key Concepts (Continued)

Concepts Summary

All key concepts for this lesson have been covered.
Use this slide to review and quiz yourself.

✓ AWS Organizations

✓ Management Account

✓ Organisational Unit (OU)

✓ Service Control Policy (SCP)

✓ FullAWSAccess SCP (default)

✓ SCP Inheritance (Root → OU → Account)

✓ Effective Permission = IAM AND SCP



Quick-Recall Test

1. Can an SCP grant permissions? (No — it only restricts)
2. Is the Management Account affected by SCPs? (No — never)
3. What is the default SCP on every account? (FullAWSAccess)
4. An SCP is attached to an OU. Does it affect nested OUs? (Yes — inherited)
5. A developer has AdministratorAccess IAM policy. An SCP blocks S3. Can they access S3? (No — SCP wins)
6. What is the intersection rule? (Effective permission = what BOTH IAM and SCP allow)



How It Works — Step by Step

1

Set Up AWS Organizations

From your Management Account, navigate to AWS Organizations and click Create Organisation. AWS creates a Root container automatically. You then invite or create member accounts. Next, create Organisational Units (OUs) to group accounts logically — e.g., a Production OU, a Development OU, and a Security OU. Accounts inherit all SCPs attached to their parent OU.

2

Write & Attach an SCP

SCPs use the exact same JSON syntax as IAM policies. Write your policy document (e.g., deny all EC2 actions outside af-south-1 and eu-west-1), then navigate to AWS Organizations → Policies → Service Control Policies, create the policy, and attach it to the target OU or account. All accounts under that OU immediately inherit the restriction — no per-account action needed.

3

How Permission Evaluation Works

Every AWS API call in a member account goes through TWO evaluations: (1) Is the action allowed by the SCP? (2) Is the action allowed by the IAM policy? Both must say YES for the request to succeed. If the SCP says Deny, the call fails — even if the IAM policy is AdministratorAccess. Think of it as a two-lock door: you need both keys to open it.



Technical Deep Dive — SCP Strategies & JSON

Two SCP Strategies

✅ DENY LIST (Recommended Default)

Keep the default FullAWSAccess SCP attached. Add explicit Deny statements on top for what is forbidden. Everything not explicitly denied remains allowed.

Best for: Most organisations starting with SCPs. Easier to manage — only forbidden actions need documentation.

🔒 ALLOW LIST (High-Security / Regulated)

Remove FullAWSAccess. Replace with an explicit Allow for only approved services (e.g., ec2:*, s3:*, rds:*). Anything not listed is implicitly denied.

Best for: Financial services (CBN compliance), healthcare, defence. High overhead — every new AWS service must be explicitly approved before use.

SCP JSON Example — Deny Non-Approved Regions

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "DenyNonApprovedRegions",
    "Effect": "Deny",
    "Action": "*",
    "Resource": "*",
    "Condition": {
      "StringNotIn": {
        "aws:RequestedRegion": [
          "eu-west-1",
          "af-south-1"
        ]
      }
    }
  }]
}
```

Architecture & Visual Model — Organisation Hierarchy



Real-World Nigerian Scenario — Zenith Group Holdings

SCENARIO: A Nigerian financial holding company — modelled on Zenith Group — operates four business units: a commercial bank, a microfinance bank, an insurance subsidiary, and a digital payments fintech. Each unit runs on a separate AWS account to satisfy CBN regulatory isolation requirements.

Commercial Bank

OU: Banking OU

Production workloads

Microfinance Bank

OU: Banking OU

Smaller compute footprint

Insurance Subsidiary

OU: Insurance OU

Actuarial data, S3 heavy

Payments Fintech

OU: Fintech OU

High-throughput Lambda/DynamoDB

SCPs Applied by the Group Security Team:

Data Residency SCP (Root)

Denies all resource creation outside eu-west-1 (Ireland) and af-south-1 (Cape Town). Ensures customer financial data never leaves CBN-approved regions. Even if a developer accidentally selects us-east-1, the API call is blocked before it reaches AWS services.

Audit Protection SCP (Root)

Denies cloudtrail:StopLogging, cloudtrail:DeleteTrail, and config:DeleteConfigRule across the entire organisation. Satisfies ISO 27001 and CBN IT risk management framework requirements for immutable audit logs.

Cost Control SCP (Dev OUs only)

Denies ec2:PurchaseReservedInstancesOffering and savingsplans:CreateSavingsPlan in all development accounts. Prevents accidental multi-year financial commitments from non-production environments.

 Discussion: What SCP would you write for a Nigerian e-commerce company to prevent its dev team from deploying public S3 buckets containing customer data?



Common Mistakes & Exam Traps

● These are the most common SAA-C03 exam errors on this topic — every one costs marks.



TRAP 1: The Management Account is exempt from all SCPs — always

No SCP — not even one attached to the Root — restricts the Management Account. This is by design. Exam questions often try to trick you by asking 'what would happen if you attached SCP X to the root?' The answer for any action in the Management Account: it is still allowed.



TRAP 2: SCPs do NOT grant permissions — they only restrict

A common distractor: 'Attach an SCP that allows s3:GetObject to grant S3 access.' WRONG. SCPs only define the ceiling. The actual Allow must come from an IAM policy. Even if an SCP allows an action, a principal still needs an IAM Allow to perform it. SCPs restrict; IAM grants.



TRAP 3: SCPs apply to the root user of member accounts

Unlike IAM policies (which cannot restrict the root user), SCPs DO restrict the root user of member accounts. If an SCP denies ec2:RunInstances, even the root user of that account cannot launch EC2. This makes SCPs more powerful than IAM for multi-account governance.



TRAP 4: FullAWSAccess is the default — SCPs start permissive

When you first enable SCPs, a FullAWSAccess policy is automatically attached to every OU and account. Nothing is restricted by default. If an exam question implies that 'enabling Organizations' automatically restricts access — that is wrong.



TRAP 5: An SCP must be ATTACHED to take effect

Creating an SCP does nothing by itself. You must explicitly attach it to the root, an OU, or an account. Exam distractors often describe a correctly written SCP that was never attached, and ask why it has no effect. The answer: it was never attached.



Question

A company has multiple AWS accounts managed through AWS Organizations. The security team wants to prevent all developers in the Development OU from creating EC2 instances in any AWS region except eu-west-1 and af-south-1. The solution must be centralised and must not require changes to IAM policies in individual accounts. Which solution meets these requirements?

A

Create an IAM permission boundary in each developer account that includes a Deny statement for `ec2:RunInstances` in non-approved regions, and attach it to all developer IAM users.

Requires per-account changes — not centralised. Permission boundaries also cannot be applied centrally across accounts via Organizations.

B

Attach a Service Control Policy to the Development OU with a Deny statement for `ec2:RunInstances` using the `aws:RequestedRegion` condition key, excluding eu-west-1 and af-south-1.

✓ CORRECT

Correct. Attaching an SCP to the OU is centralised, automatically inherited by all accounts in the OU, and cannot be overridden by any IAM policy within those accounts.

C

Attach an SCP to the Management Account that denies `ec2:RunInstances` in all non-approved regions.

The Management Account is never subject to SCPs. Attaching an SCP to the management account restricts only principals in the management account — it does not propagate to the Development OU.

D

Create an AWS Config rule in each development account that automatically terminates EC2 instances launched in non-approved regions via an SSM automation remediation.

Config rules are detective, not preventive. Instances are created before the remediation fires. Also requires per-account setup — not centralised.

Key Takeaways — What You Learned Today

SCPs & AWS Organizations

Concepts Covered

- ✓ AWS Organizations — consolidate multi-account governance
- ✓ Management Account — controls the org, never SCP-restricted
- ✓ Organisational Units (OUs) — hierarchical account grouping
- ✓ Service Control Policies — permissions ceiling, not grants
- ✓ Deny List vs Allow List SCP strategies
- ✓ SCP Inheritance: Root → OU → Account (additive)
- ✓ Effective permission = IAM AND SCP intersection
- ✓ SCPs restrict root users of member accounts

Before Next Class

1. Review all concepts above without your notes — close the deck and recall from memory
2. Complete the hands-on lab: Create an AWS Organization, add an OU, write a deny-region SCP, and attach it
3. Log into the AWS console and navigate to Organizations → Policies — explore the built-in SCP examples
4. Re-read the five exam traps from the previous slide — write each one out by hand
5. Post your lab screenshot and one thing you learned on the WhatsApp group
6. Read the AWS SCP Examples documentation (link on next slide)



Further Resources & Reading

Go deeper with these official AWS and industry resources:



AWS Organizations User Guide

OFFICIAL DOCS

<https://docs.aws.amazon.com/organizations/latest/userguide/>

Official documentation covering org creation, OU structure, account management, and policy attachment workflows. Start here for authoritative reference.



SCP Syntax & Examples (AWS Docs)

EXAMPLES LIBRARY

https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_scps_examples.html

A curated library of production-ready SCP examples: restrict root user actions, deny region usage, prevent leaving the org, require MFA, and more. Bookmark this.



AWS Control Tower Documentation

RELATED SERVICE

<https://docs.aws.amazon.com/controltower/latest/userguide/>

Control Tower is the managed orchestration layer on top of Organizations. It automates multi-account landing zone setup with pre-built guardrails (SCPs). Relevant for SAA-C03 scenarios involving 'landing zones'.



SAA-C03 Exam Guide — Domain 2

EXAM PREP

https://d1.awsstatic.com/training-and-certification/docs-sa-assoc/AWS-Certified-Solutions-Architect-Associate_Exam-Guide.pdf

Download the official exam guide and read Domain 2: Design Secure Architectures. SCPs, Organizations, IAM, and identity federation are weighted heavily. Know the exact AWS service boundaries tested.



AWS re:Invent — Multi-Account Best Practices

VIDEO CONTENT

https://www.youtube.com/results?search_query=aws+reinvent+organizations+scp+multi+account

Search 'AWS re:Invent Organizations SCP' on YouTube. The SEC301 and SEC401 sessions are particularly strong for understanding real enterprise-scale governance architectures.



Homework: Read at least ONE resource above before next class. Post what you learned on the WhatsApp group.



Week 2 · Day 3 Complete

SCPs & AWS Organizations

IAM & Security

Next: Hands-on Console Lab →

basestack.academy · Cohort 1 · AWS Cloud Accelerator